Office of Information Technology Services

State Capitol P.O. Box 2062
Albany, NY 12220-0062
www.its.ny.gov

New York State Information Technology Policy	**No:** NYS-P26-001
IT Policy: **Cybersecurity Supply Chain Risk Management**	**Updated:** 09/09/2026
	Issued By: NYS Office of Information Technology Services **Owner:** Chief Information Security Office

1.0 Purpose and Benefits

The purpose of this policy is to provide guidelines for the implementation of effective Cybersecurity Supply Chain Risk Management (C-SCRM) practices for systems and organizations. C-SCRM is a systematic process for managing security risks in the products and services procured to conduct State business. C-SCRM is a subset of overall cybersecurity and application risk management. This policy addresses the potential threats and vulnerabilities that may arise from third party vendors and their subcontractors, suppliers, and their products and services throughout the supply chain. By establishing a systematic process to assess, monitor, and mitigate supply chain risks to SE assets and functions, this policy ensures that the products and services procured for State business are trustworthy and secure.

This policy applies to cybersecurity risks arising from both Information Technology (IT) and Operational Technology (OT) products, services, and their supply chains.

2.0 Authority

Section 103(10) of the State Technology Law provides the Office of Information Technology Services (ITS) with the authority to establish statewide technology policies, including technology and security standards. *Section 2 of Executive*

Order No. 117[1] provides the State Chief Information Officer with the authority to oversee, direct and coordinate the establishment of information technology policies, protocols and standards for State government, including hardware, software, security and business re-engineering. Details regarding this authority can be found in NYS ITS Policy, *NYS-P08-002 Authority to Establish State Enterprise Information Technology (IT) Policy, Standards and Guidelines*.

3.0 Scope

This policy applies to all "State Entities" (SE), defined as "State Government" in Executive Order 117 or "State Agencies" as defined in Section 101 of the State Technology Law. This includes employees of the SE and ITS, and all third parties (such as local governments, consultants, vendors, and contractors) that use or access any Information Technology (IT) Resource or Operational Technology for which the SE or ITS has administrative responsibility, including systems managed or hosted by third parties on behalf of the SE or ITS. While an SE may adopt a different policy, it must include the requirements set forth in this one. Where a conflict exists between this policy and a SE's policy, the more restrictive requirement will take precedence.

4.0 Information Statement

All SEs must implement a C-SCRM program. At a minimum, a C-SCRM program must consist of the elements outlined in this policy. The resulting C-SCRM documentation will then describe the program, procedures, and responsible parties.

SEs are encouraged, but not required, to come up with a C-SCRM implementation plan to guide its C-SCRM program. An implementation plan outlines an SE's C-SCRM program, procedural details, and responsible parties. For a sample C-SCRM implementation plan, see NIST 161r1-upd1 Appendix D.1.

4.1 What is Cybersecurity Supply Chain Risk Management?

C-SCRM is the process of managing risk inherent to distributed and globally connected technology systems. Most, if not all, technology solutions used by SEs will rely on a complex chain of supporting technologies. For instance, if a government agency procures a cloud-based HR management software from an outside vendor, components of the supply chain include, but not be limited to:

- the computers used to access the software

[1] All references to Executive Order 117 refer to that which was originally issued by Governor George E. Pataki on January 28, 2002, and continued by Executive Order 5 issued by Governor Eliot Spitzer on January 1, 2007, Executive Order 9 issued by Governor David A. Patterson on June 18, 2008, Executive Order 2 issued by Governor Andrew M. Cuomo on January 1, 2011, and Executive Order 6 issued by Governor Kathy Hochul on October 8, 2021.

- the servers hosting the software
- the code in the software that may have been sourced from open-source libraries and third-party tools
- the Software Bill of Materials (SBOM)
- the contract between the agency and the vendor as well as between the vendor and its subcontractors and suppliers.

Cybersecurity risks throughout the supply chain arise from the risks posed by suppliers, their supply chains, and their products and services. A non-exhaustive list of examples of these risks include:

- a company is on contract with government agencies to produce a critical component of a larger computer system, but the company subcontracts with an unvetted supplier who cannot meet the required performance. This would negatively impact the design within the larger computer system which could disrupt operations and services performed, resulting in increased maintenance, repair costs, and possible downtime.
- a company that designs and manufactures Operational Technology (OT) devices, has leveraged a chipset in their design. However, the supplier of chipset has implanted malware for a future attack, which could result in compromise of sensitive data.

C-SCRM is the process by which an organization identifies, assesses, and mitigates such risks.

4.2 Requirements of a C-SCRM Program

A formal C-SCRM program establishes governance, processes, and tools necessary to identify, assess, and mitigate cybersecurity risks throughout an SEs supply chain.

C-SCRM requires a multilevel risk management program:



Figure 1: Multilevel risk management program structure (adapted from NIST SP 800- 161r1 Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations)

- **Level 1**: At the **SE mission, strategy, and governance** level, executive leadership at the SE establishes a SE-wide C-SCRM plan and sets a clear vision to provide direction and insight into the development and execution of C-SCRM activities. Executive leadership is responsible for framing risk and SE, setting the tone for how risk is managed, and delegating decisions to Level 2 and Level 3. For example, leadership provides an overarching C-SCRM strategy to identify and mitigate all cybersecurity risks throughout the supply chain consistent with the goals and objectives of the SE. Level 1 decision makers not only facilitate collaboration across organizational lines of responsibility but prioritize resource allocation for C-SCRM based on their defined risk reporting and escalation process.

- **Level 2**: At the **policy, standard, and implementation plan** level, representatives of each functional and business line perform activities in accordance with C-SCRM implementation plans provided by Level 1, such as:

    - procurement and contract review
    - vendor/supplier assessment
    - identification and response to risks arising from their business process dependencies on third party vendors, suppliers, and other IT/OT service providers
    - business continuity and incident response planning

    For example, Level 2 authorized personnel can develop acquisition policies and processes to determine what types of information systems should be subject to C-SCRM and plans for unexpected supply chain-related interruptions for business continuity. Level 2 appointees may further delegate responsibilities to Level 3 designated officials who are responsible for day-to-day management of risk. Level 2 appointees are also responsible for reporting back to Level 1, demonstrating how their responsible business process performs against the SE-defined risk appetite and risk tolerance.

    Associated policy: NYS-P03-002 Information Security, NYS-S13-005 Cyber Incident Response, NYS-S14-001 Information Security Risk Management, NYS-P08-001 Plan to Procure

- **Level 3**: The **operating procedure** level comprises personnel responsible for day-to-day operational activities. These personnel conduct C-SCRM activities throughout the System Development Life Cycle which include acquisition, development, maintenance, data sanitization, and secure disposal of system components supporting the SE's mission and business process. Examples of Level 3 activities include: evaluating third party vendors' evidence of compliance with contractual cybersecurity

requirements; monitoring supplier criticality; and risk impact throughout the supplier relationship lifecycle.

Associated standard: NYS-S13-001 Secure System Development Life Cycle, NYS-S13-003 Sanitization / Secure Disposal

4.2.1 Compliance with Relevant Laws, Rules, and Policies

C-SCRM programs must comply with all relevant federal and state laws, rules, and policies. SEs should consult their legal team to identify all laws, rules and policies applicable to their C-SCRM program.

Listed below are examples of laws, rules, and policies that could apply to all SEs:

1. NYS Information Security Policies and Standards
2. IRS Publication 1075: Tax Information Security Guidelines
3. Health Insurance Portability and Accountability Act
4. Family Educational Rights and Privacy Act
5. Preventing Access to U.S. Sensitive Personal Data and Government-Related Data by Countries of Concern or Covered Persons, 28 CFR Part 202.

4.3 Program Revision, Maintenance, and Enhancement

The successful execution of C-SCRM and sustained operational effectiveness require a commitment to progress tracking. The SE needs to track, monitor, and evaluate the progress of the C-SCRM Program as well as the security of their supply chain including but not limited to third party cloud and technology providers. The SE should then continuously incorporate lessons learned from C-SCRM activities into the policy, process, and training to enhance their ability to assess, respond to, and monitor cybersecurity risks throughout the supply chain.

The implementation plans must be reviewed periodically, at a frequency defined by the SE to reflect any changes. Such changes include internal system changes, supplier operational or structural changes, product updates, or any other environmental changes relating to laws, policies, standards, controls, and technologies.

5.0 Compliance

This policy shall take effect upon publication. Compliance is expected with all enterprise policies and standards. ITS may amend its policies and standards at any time; compliance with amended policies and standards is expected.

If compliance with this policy is not feasible or technically possible, or if deviation from this policy is necessary to support a business function, State Entities shall request an exception through the Chief Information Security Office exception process.

6.0 Definitions of Key Terms

Except for terms defined in this policy, all terms shall have the meanings found in the ITS Glossary.

Term	Definition
Software Bill of Materials (SBOM)	A formal record containing the details and supply chain relationships of various components used in building software.

7.0 Contact Information

Submit all inquiries and requests for future enhancements to the policy owner at:

Chief Information Security Office
Reference: NYS-P26-001
NYS Office of Information Technology Services
31 British American Blvd.
Latham, NY 12110
Telephone: 518-242-5200
Email: CISO@its.ny.gov

Statewide technology policies, standards, and guidelines may be found on the Polices page of the ITS website.

8.0 Revision History

This standard should be reviewed consistent with the requirements set forth in ITS-P24-003 Process for Establishing Information Technology Policies, Standards and Guidelines.

Date	Description of Change	Reviewer
09/09/2026	Issued policy	Chris DeSain, Chief Information Security Officer

9.0 Related Documents

NIST Special Publication 800-53 Revision 5 Security and Privacy Controls for Information Systems and Organizations

NIST Special Publication 800 Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations

NIST Cybersecurity Framework 2.0: Quick-Start Guide for Cybersecurity Supply Chain Risk Management (C-SCRM)

General Services Administration Cybersecurity Supply Chain Risk Management (C-SCRM) Acquisition Guide

Securing the Software Supply Chain Recommended Practices for Software Bill of Materials Consumption

10.0 Appendix A: C-SCRM Policy Templates for Level 1 and Level 2, adapted from NIST SP 800-161r1-upd1

The C-SCRM policies direct the implementation of the C-SCRM strategy. The C-SCRM policies can be developed at Level 1 and/or at Level 2 and are informed by mission- and business-specific factors, including risk context, risk decisions, and risk activities from the C-SCRM strategy.

The C-SCRM policies support applicable SE policies (e.g., acquisition and procurement, information security and privacy, logistics, quality, and supply chain). The C-SCRM policies should address mission and business functions, as well as internal and external customer requirements. C-SCRM policies also define the integration points for C-SCRM with the risk management processes for the SE. Finally, the C-SCRM policies define the C-SCRM roles and responsibilities within the SE at a more specific and granular level, any interdependencies among those roles, and the interaction between the roles.

The C-SCRM policies at Level 1 are broader, whereas the C-SCRM policies at Level 2 are specific to the mission and business function. C-SCRM roles specify the responsibilities for procurement, conducting risk assessments, collecting supply chain threat intelligence, identifying and implementing risk-based mitigations, monitoring, and other C-SCRM functions.

[SE] Information Technology Policy	**No:** XXX-XXX-XXX
Policy **Level 1 Policy Template**	**Updated: XX/XX/XXXX**
	Issued By: [SE] **Owner: [SE Chief Information Security Officer]**

1.0 Authority and Compliance

- Policies
  - NYS-P26-001 Cybersecurity Supply Chain Risk Management
  - NYS-P03-002 Information Security
  - NYS-S14-001 Information Security Risk Management
- Legislation
  - Health Insurance Portability and Accountability Act of 1996 (HIPAA)
  - Family Educational Rights and Privacy Act of 1974 (FERPA)
- Regulations
  - IRS Publication 1075: Tax Information Security Guideline
  - Preventing Access to U.S. Sensitive Personal Data and Government-Related Data by Countries of Concern or Covered Persons, 28 CFR Part 202.

2.0 Description

The policy objective of the [SE's] C-SCRM Program is to successfully implement and sustain the capability of providing improved assurance that the products, services, and solutions used and offered by [the SE] are trustworthy, appropriately secure and resilient, and able to perform to the required quality standard.

C-SCRM is a systematic process for identifying and assessing susceptibilities, vulnerabilities, and threats throughout the supply chain and implementing strategies and mitigation controls to reduce risk exposure and combat threats. The establishment and sustainment of an SE-wide C-SCRM Program will enable [the SE's] risk owners to identify, assess, and mitigate supply chain risk to [the SE's] mission assets, functions, and associated services.

3.0 Policy

[SE's] enterprise-level C-SCRM Program is established to implement and sustain the capability to:

- Assess and provide appropriate risk response to cybersecurity risks that arise from the acquisition and use of covered articles;
- Prioritize assessments of cybersecurity risks throughout the supply chain and risk response actions based on criticality assessments of the mission, system, component, service, or asset;
- Develop an overall C-SCRM strategy and high-level implementation plan, policies, and processes;
- Integrate supply chain risk management practices throughout the acquisition and asset management life cycle of covered articles;
- Share C-SCRM information in accordance with industry-wide criteria and guidelines; and
- Guide and oversee implementation progress and program effectiveness.

The C-SCRM Program shall:

- Be centrally led and coordinated by designated senior leadership who shall function as [the SE's] C-SCRM Program Executive and chair the C-SCRM Program Management Office (PMO);
- Leverage and be appropriately integrated into [the SE's] existing risk management and decision-making governance processes and structures;
- Reflect a team-based approach and be collaborative, interdisciplinary, and intra-enterprise in nature and composition;
- Incorporate a multilevel risk management approach that is consistent with the NIST Risk Management Framework and NIST SP 800-161, Rev. 1; and Implement codified and regulatory C-SCRM requirements and industry-wide and SE-specific policy direction, guidance, and processes.

4.0 Roles and Responsibilities

The C-SCRM Program Executive shall be responsible for:

- Leading the establishment, development, and oversight of the C-SCRM Program in coordination and consultation with designated C-SCRM Leads.
- Establishing and serving as the Chair of the C-SCRM PMO. This team will be comprised of the chair and the designated C-SCRM Leads and will be responsible for developing and coordinating C-SCRM strategy, implementation plans, and actions that address C-SCRM-related issues; program reporting and oversight; and identifying and making program resource recommendations.

- Escalating and/or reporting C-SCRM issues to Senior Officials, as may be appropriate.

Each C-SCRM Security Officer shall be responsible for:

- Identifying C-SCRM Leads (the Lead will be responsible for participating as a collaborative and core member of the C-SCRM PMO);
- Incorporating relevant C-SCRM functions into enterprise- and position-level functions; and
- Implementing and conforming to C-SCRM Program requirements.

5.0 Definitions

- **Covered Articles**: Information technology, including cloud computing services of all types; telecommunications equipment or telecommunications services; the processing of information on a federal or non-federal information system, subject to the requirements of the Controlled Unclassified Information program; and all IoT/OT (e.g., hardware, systems, devices, software, or services that include embedded or incidental information technology).
- **Cybersecurity Supply Chain Risk Assessment**: A systematic examination of cybersecurity risks throughout the supply chain, the likelihoods of their occurrence, and potential impacts.
- **Risk Owner**: A person or entity with the accountability and authority to manage a risk.

6.0 Revision and Maintenance

[SE's] C-SCRM policy must be reviewed every three years, at minimum, since changes to laws, policies, standards, guidelines, and controls are dynamic and evolving. Additional criteria that may trigger interim revisions include:

- A change of policies that impact the C-SCRM policy,
- Significant C-SCRM events,
- The introduction of new technologies,
- The discovery of new vulnerabilities,
- Operational or environmental changes,
- Shortcomings in the C-SCRM policy,
- A change of scope, and
- Other SE-specific criteria.

Date	Description of Change	Reviewer
09/09/2026	Issued policy	Chief Information Security Office